

# SGSI - Sistema de Gestión de Seguridad de la Información

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

**Universidad Nacional del Centro del Perú (UNCP)**

**Marco Conceptual General**

---

## 1. ¿Qué es un SGSI?

Sistema de gestión basado en la norma **ISO/IEC 27001** que permite establecer, implementar, mantener y mejorar continuamente la seguridad de la información en una organización.

Cubre **TODO tipo de información**, sin importar su formato:

| Tipo                        | Ejemplos en UNCP                                                              |
|-----------------------------|-------------------------------------------------------------------------------|
| <b>Digital</b>              | Bases de datos, sistemas (SIGA, campus virtual, correo), archivos, respaldos  |
| <b>Física (papel)</b>       | Actas de notas, expedientes de estudiantes, contratos, resoluciones, informes |
| <b>Transmitida</b>          | Videoconferencias, llamadas, conversaciones                                   |
| <b>Almacenada en medios</b> | Discos duros, USB, CD/DVD, cintas de backup                                   |

Principios fundamentales: **Confidencialidad, Integridad, Disponibilidad (CID)**.

---

## 2. Información Física vs. Digital - Tratamiento Diferenciado

### Información Física (soporte papel)

| Aspecto                 | Consideraciones UNCP                                                                   |
|-------------------------|----------------------------------------------------------------------------------------|
| <b>Archivos físicos</b> | Oficinas de registros académicos, tesorería, recursos humanos, secretarías de facultad |
| <b>Expedientes</b>      | Almacenados en estantes, archivadores, cajas. Control de acceso físico                 |
| <b>Actas de notas</b>   | Firmadas manualmente, resguardadas en archivos centrales                               |
| <b>Contratos</b>        | Versiones impresas con firmas ológrafas                                                |
| <b>Resoluciones</b>     | Emitidas por rectorado y facultades, archivadas en físico                              |
| <b>Tesis</b>            | Copias físicas en bibliotecas central y facultades                                     |

### Protección de información física (Controles A.7, A.11)

| Medida                                | Descripción                                                                    |
|---------------------------------------|--------------------------------------------------------------------------------|
| <b>Control de acceso físico</b>       | Puertas con llave, tarjetas de proximidad, biométricos                         |
| <b>Áreas seguras</b>                  | Sala de servidores, archivos centrales, tesorería                              |
| <b>Perímetro de seguridad</b>         | Vigilancia, cámaras, alarmas en edificios clave                                |
| <b>Escritorios limpios (A.11.2.9)</b> | Documentos sensibles guardados bajo llave al retirarse                         |
| <b>Pantallas limpias (A.11.2.9)</b>   | Bloqueo de pantalla automático, documentos visibles solo a personal autorizado |
| <b>Destrucción segura</b>             | Trituradoras de papel certificadas para documentos confidenciales              |
| <b>Archivo histórico</b>              | Control de acceso, condiciones ambientales (temperatura, humedad, plagas)      |

### 3. Estructura del SGSI según ISO 27001 (Cláusulas 4-10)

#### Cl. 4 - Contexto de la organización

**Partes interesadas internas:** - Rectorado, vicerrectorados, decanos, directores de escuela - Docentes, estudiantes, personal administrativo - Comité Electoral Universitario, Asamblea Universitaria

**Partes interesadas externas:** - SUNEDU, MINEDU, CGR, PCM - Proveedores de servicios TI (internet, cloud, licencias) - Postulantes y público en general

**Requisitos legales aplicables:** - Ley N° 29158 - Ley Orgánica del Poder Ejecutivo - Ley N° 29733 - Ley de Protección de Datos Personales - **D.S. N° 016-2024-JUS** - Nuevo Reglamento de la Ley N° 29733, vigente desde marzo 2025. Introduce DPIA, regulación de IA y transferencias internacionales de datos - Decreto Legislativo N° 1412 - Ley de Gobierno Digital - D.S. N° 029-2021-PCM - Reglamento de la Ley de Gobierno Digital - **D.S. N° 098-2025-PCM** - Modifica el D.S. N° 029-2021-PCM. Actualiza condiciones de identidad digital, servicios digitales, interoperabilidad y gestión documental electrónica en el Estado - D.S. N° 033-2018-PCM - Plataforma Digital Única del Estado Peruano - D.S. N° 103-2023-PCM - Política Nacional de Transformación Digital - **Ley N° 31814 y D.S. N° 115-2025-PCM** - Ley que promueve el uso de la IA y su Reglamento. Exige auditoría de algoritmos, supervisión humana y gestión de riesgos éticos en entidades públicas - R.M. N° 119-2018-PCM - Comité de Gobierno Digital - R.S. N° 005-2018-PCM/SGTD - Lineamientos para formulación del PGTD - R.S. N° 004-2018-PCM/SGTD - Lineamientos para gestión del Gobierno Digital - **R.S. N° 001-2025-PCM/SGTD** - Lineamiento para el diseño y desarrollo de servicios digitales accesibles para personas con discapacidad (WCAG 2.2) - **Directiva N° 001-2025-PCM/SGTD** - Directiva que regula el consumo seguro de los servicios de información de la PIDE y establece medidas de seguridad digital - Ley N° 27209 - Ley de Presupuesto del Sector Público - Directiva N° 006-2019-CG/INTEG - Sistema de Control Interno - Resolución N° 322-2026-CG - Plan de Gobierno y Transformación Digital CGR - Estatuto de la UNCP

#### Cl. 5 - Liderazgo

Conforme a la R.M. N° 119-2018-PCM y los Lineamientos del PGTD (R.S. N° 005-2018-PCM/SGTD):

| Rol                                             | Responsabilidad                                                                               |
|-------------------------------------------------|-----------------------------------------------------------------------------------------------|
| <b>Rector</b>                                   | Titular de la entidad, preside el Comité de Gobierno Digital, máxima responsabilidad del SGSI |
| <b>Comité de Gobierno Digital</b>               | Dirige, evalúa y supervisa la transformación digital y el SGSI                                |
| <b>Secretario Técnico del Comité</b>            | Elabora actas, coordina agenda, registra información del PGTD                                 |
| <b>Oficial de Seguridad y Confianza Digital</b> | Lidera el SGSI operativamente, reporta al Comité                                              |
| <b>Decanos / Directores</b>                     | Responsables de la seguridad de la información en sus unidades                                |
| <b>Todos los colaboradores</b>                  | Obligación de reportar incidentes de seguridad                                                |

#### Cl. 6 - Planificación

**Evaluación de riesgos:** - Identificación de activos (digitales y físicos) - Identificación de amenazas y vulnerabilidades - Análisis de impacto (pérdida de notas, filtración de datos personales, etc.) - Plan de tratamiento de riesgos

**Declaración de Aplicabilidad (SoA):** - Define qué controles del Anexo A son aplicables a la UNCP

#### Cl. 7 - Soporte

**Recursos:** - Presupuesto para seguridad (software, hardware, personal) - Infraestructura física y lógica

**Competencia:** - Capacitación obligatoria en seguridad para todo el personal - Formación específica para el equipo SGSI

**Concientización:** - Campañas de phishing simuladas - Charlas sobre seguridad de información física y digital - Inducción para nuevos ingresantes y personal

**Documentación:** - Política SGSI, procedimientos, registros, manuales

#### **Cl. 8 - Operación**

- Implementación de controles
- Gestión de riesgos en operaciones diarias
- Gestión de cambios (nuevos sistemas, procesos, personal)
- Gestión de incidentes de seguridad

#### **Cl. 9 - Evaluación**

- Auditorías internas periódicas
- Revisión del SGSI por la alta dirección (anual)
- Medición de indicadores de eficacia

#### **Cl. 10 - Mejora**

- Gestión de no conformidades
  - Acciones correctivas y preventivas
  - Mejora continua del SGSI
-

#### 4. Controles del Anexo A ISO 27001 — Aplicación en UNCP

| Dominio                            | Controles clave                                         | Digital | Física |
|------------------------------------|---------------------------------------------------------|---------|--------|
| <b>A.5 Políticas</b>               | Política de seguridad, revisión                         | x       | x      |
| <b>A.6 Organización interna</b>    | Roles, segregación, contacto autoridades                | x       | x      |
| <b>A.7 RRHH</b>                    | Inducción, capacitación, disciplinario, desvinculación  | x       | x      |
| <b>A.8 Gestión de activos</b>      | Inventario, clasificación, manejo de medios             | x       | x      |
| <b>A.9 Control de acceso</b>       | Acceso a sistemas, VPN, roles, privilegios              | x       | x      |
| <b>A.10 Criptografía</b>           | Cifrado de datos sensibles, firmas digitales            | x       |        |
| <b>A.11 Seguridad física</b>       | Perímetro, salas seguras, escritorio limpio, CCTV       |         | x      |
| <b>A.12 Operaciones</b>            | Backups, protección malware, gestión cambios, logs      | x       |        |
| <b>A.13 Comunicaciones</b>         | Firewall, segmentación de red, VPN, correo seguro       | x       |        |
| <b>A.14 Adquisiciones</b>          | Desarrollo seguro, pruebas, aceptación                  | x       |        |
| <b>A.15 Relaciones proveedores</b> | Contratos con ISPs, servicios cloud, SaaS               | x       | x      |
| <b>A.16 Incidentes</b>             | Reporte, clasificación, respuesta, lecciones aprendidas | x       | x      |
| <b>A.17 Continuidad</b>            | BCP y DRP para sistemas críticos                        | x       | x      |
| <b>A.18 Cumplimiento</b>           | Ley 29733, D.L. 1412, transparencia, CGR                | x       | x      |

## 5. Activos críticos de información en la UNCP

### Digitales

| Activo                                             | Riesgo si se pierde/filtra                          |
|----------------------------------------------------|-----------------------------------------------------|
| Base de datos académica (matrícula, notas, grados) | Pérdida de historial académico, procesos judiciales |
| Sistema de tesorería / recaudación                 | Fraude financiero, pérdida económica                |
| Correo institucional                               | Suplantación, phishing, fuga de información         |
| Plataforma campus virtual                          | Interrupción de servicio educativo                  |
| Repositorio de tesis e investigación               | Pérdida de propiedad intelectual                    |
| Sistema de planillas (RRHH)                        | Fuga de datos personales de trabajadores            |
| Servidor de archivos compartidos                   | Pérdida de documentos institucionales               |

### Físicos

| Activo                          | Ubicación                       | Riesgo                        |
|---------------------------------|---------------------------------|-------------------------------|
| Actas de notas originales       | Archivo central / facultades    | Pérdida, deterioro, incendio  |
| Expedientes de grados y títulos | Secretaría general              | Pérdida, falsificación        |
| Contratos y convenios           | Oficina de planeamiento / legal | Pérdida, disputas legales     |
| Resoluciones rectorales         | Archivo central                 | Pérdida de legalidad de actos |
| Declaraciones juradas           | RRHH / OCI                      | Fuga de datos personales      |
| Tesis impresas                  | Biblioteca central / facultades | Deterioro, extravío           |

## 6. Mapa de transición AS-IS → TO-BE (vista general)

| Dimensión                       | AS-IS (actual)                                   | TO-BE (deseado)                                                                                 |
|---------------------------------|--------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>Políticas</b>                | Dispersas, no formalizadas                       | Política SGSI aprobada por rectorado, comunicada a toda la UNCP                                 |
| <b>Organización</b>             | Sin Oficial de Seguridad designado               | Comité de Gobierno Digital activo + Oficial de Seguridad                                        |
| <b>Seguridad física</b>         | Acceso sin control en varias facultades          | Controles perimetrales, archivadores con llave, cámaras, bitácoras                              |
| <b>Seguridad digital</b>        | Sin segmentación de red, backups no validados    | Red segmentada, backups periódicos probados, firewall                                           |
| <b>Documentos físicos</b>       | Archivos sin clasificación de seguridad          | Documentos clasificados (público, interno, confidencial, secreto)                               |
| <b>Control de acceso</b>        | Usuarios compartidos, contraseñas débiles        | Acceso por roles, 2FA, política de contraseñas                                                  |
| <b>Incidentes</b>               | No se reportan formalmente                       | Procedimiento de gestión de incidentes, CSIRT universitario                                     |
| <b>Concientización</b>          | Mínima o nula                                    | Programa permanente de capacitación y simulacros                                                |
| <b>Cumplimiento legal</b>       | Parcial (Ley 29733, D.L. 1412)                   | Cumplimiento auditado, reportes a CGR y PCM                                                     |
| <b>Mejora continua</b>          | No existe ciclo de mejora                        | Auditorías internas, revisión por dirección, acciones correctivas                               |
| <b>Monitoreo de red</b>         | Sin TAP, IDS/IPS ni SNMPv3                       | TAP físico en Datacenter + SPAN en facultades + NetFlow/IPFIX en routers + SNMPv3 cifrado (AES) |
| <b>Alta disponibilidad</b>      | Servidores físicos sin clustering ni replicación | Nube Híbrida Activo-Activo (Proxmox/Ceph o vSAN) + GSLB + Contenedores Docker/Kubernetes        |
| <b>Segmentación de red</b>      | Ausente en la mayoría de facultades              | Microsegmentación ZTNA + VLANs por tipo de usuario + 802.1X                                     |
| <b>Conectividad entre sedes</b> | VPNs estáticas sin priorización                  | SD-WAN con túneles IPsec dinámicos entre 4 sedes                                                |
| <b>Conectividad cloud</b>       | Ninguna                                          | AWS Direct Connect / Azure ExpressRoute a PNGD-PCM                                              |
| <b>SIEM</b>                     | Inexistente                                      | Wazuh / Microsoft Sentinel con IA para detección de DDoS y SQLi                                 |

## 7. Normativa peruana relacionada

| Norma                                                                            | Relación con SGSI                                                                                                   |
|----------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| <b>Ley N° 29733</b> - Protección de Datos Personales                             | Exige medidas de seguridad para datos personales (estudiantes, docentes)                                            |
| <b>D.S. N° 016-2024-JUS</b> - Nuevo Reglamento de la Ley N° 29733                | Introduce DPIA, regulación de IA y transferencias internacionales de datos. Vigente desde marzo 2025                |
| <b>D.L. N° 1412</b> - Ley de Gobierno Digital                                    | Marco para gobierno digital en entidades públicas                                                                   |
| <b>D.S. N° 029-2021-PCM</b> - Reglamento de la Ley de Gobierno Digital           | Procedimientos y condiciones para gobierno digital                                                                  |
| <b>D.S. N° 098-2025-PCM</b> - Modificatoria del D.S. N° 029-2021-PCM             | Actualiza condiciones de identidad digital, servicios digitales, interoperabilidad y gestión documental electrónica |
| <b>D.S. N° 033-2018-PCM</b> - Plataforma Digital Única                           | Digitalización de servicios públicos                                                                                |
| <b>D.S. N° 103-2023-PCM</b> - PNTD                                               | Alinea al Sistema Nacional de Transformación Digital                                                                |
| <b>Ley N° 31814 y D.S. N° 115-2025-PCM</b> - Ley de IA y su Reglamento           | Exige auditoría de algoritmos, supervisión humana y registro de sistemas de riesgo alto en entidades públicas       |
| <b>R.M. N° 119-2018-PCM</b> - Comité de Gobierno Digital                         | Crea el Comité de Gobierno Digital en cada entidad                                                                  |
| <b>R.S. N° 005-2018-PCM/SGTD</b> - Lineamientos PGTD                             | Estructura y contenido mínimo del Plan de Gobierno y Transformación Digital                                         |
| <b>R.S. N° 001-2025-PCM/SGTD</b> - Lineamiento de accesibilidad digital          | Diseño y desarrollo de servicios digitales accesibles para personas con discapacidad (WCAG 2.2)                     |
| <b>Directiva N° 001-2025-PCM/SGTD</b> - Consumo seguro de servicios PIDE         | Regula las medidas de seguridad digital para interoperabilidad y respuesta a incidentes                             |
| <b>Resolución N° 322-2026-CG</b> - Plan de Gobierno y Transformación Digital CGR | Directrices para implementación en entidades sujetas a control                                                      |
| <b>Directiva N° 006-2019-CG/INTEG</b> - SCI                                      | Implementación del Sistema de Control Interno                                                                       |
| <b>ISO/IEC 27001:2022</b>                                                        | Estándar internacional para SGSI                                                                                    |

## 8. SGSI y Plan de Gobierno y Transformación Digital (PGTD)

El SGSI se articula directamente con el Plan de Gobierno y Transformación Digital (PGTD) de la UNCP en los siguientes aspectos:

| Componente PGTD                                      | Relación con SGSI                                          |
|------------------------------------------------------|------------------------------------------------------------|
| <b>Objetivo OGD.01</b> - Servicios digitales         | Requiere controles de seguridad (A.9, A.13, A.14)          |
| <b>Objetivo OGD.02</b> - Seguridad de la información | Núcleo del SGSI (todas las cláusulas 4-10)                 |
| <b>Objetivo OGD.04</b> - Modernización TI            | Implementa controles de infraestructura (A.11, A.12, A.13) |
| <b>Proyecto PGTD-01</b> - Implementación SGSI        | Proyecto principal de seguridad basado en ISO 27001        |
| <b>Proyecto PGTD-06</b> - Gestión de incidentes      | Control A.16 - Gestión de incidentes de seguridad          |
| <b>Desafío 5</b> - Seguridad de la información       | Alineado con los 3 principios CID del SGSI                 |

El PGTD de la UNCP incluye el proyecto PGTD-01 “Implementación del SGSI basado en ISO 27001” con un horizonte 2026-2030 y un presupuesto estimado de S/ 850,000.

## 9. Próximos pasos

1. **AS-IS (actual):** Levantamiento completo de activos (digitales + físicos), procesos, riesgos actuales, brechas
  2. **TO-BE (deseado):** Arquitectura objetivo, controles a implementar, procesos rediseñados
  3. **Plan de implementación:** Cronograma, recursos, presupuesto, responsables
  4. **Certificación:** Auditoría interna → certificación ISO 27001
- 

*Documento: SGCI-UNCP-MC-001 Versión: 1.1 Estado: Borrador conceptual (mejorado) Documentos relacionados: PGTD-UNCP 2026-2030, R.S. N° 005-2018-PCM/SGTD*